

SOC INVESTIGATION REPORT

LetsDefend Blue Team Lab

analyst :Mehenni May

SOC138 — Detected Suspicious XLS File

CVE-2017-11882 Exploit — Obfuscated Macro Dropper — Confirmed C2 Beaconing

Event ID	77
Event Time	Mar 13, 2021 — 08:20 PM UTC
Rule Name	SOC138 - Detected Suspicious Xls File
Alert Type	Malware
MITRE Kill Chain	T1566 → T1203 → T1059 → T1105 → T1573 (full chain confirmed)
Alert Severity	Medium (Analyst-Assessed: HIGH)
Affected Host	Sofia — 172.16.17.56 — Windows 10 — User: Sofia2020
Final Verdict	TRUE POSITIVE — ACTIVE COMPROMISE

Report Date: March 3, 2026 — LetsDefend SOC Lab

1. Executive Summary

On March 13, 2021, host Sofia (172.16.17.56) received and executed a macro-enabled Excel file disguised as a procurement document. The file exploited CVE-2017-11882, a critical Microsoft Equation Editor vulnerability patched in 2017, to execute code without requiring any user interaction beyond opening the document. A multi-stage attack chain followed: obfuscated VBA macros launched a Base64-encoded PowerShell downloader, which retrieved a second-stage executable (Podaliri4.exe) from an attacker-controlled domain. Within the same minute, firewall telemetry confirmed encrypted outbound traffic to the C2 server on port 443.

The endpoint was not isolated, the malware was not quarantined, and no PowerShell execution controls were in place. The email gateway was bypassed entirely via a password-protected ZIP archive. Given the active C2 session and uncontained endpoint, full host compromise must be assumed. Credential theft, lateral movement, and data exfiltration are live risks until containment is enforced.

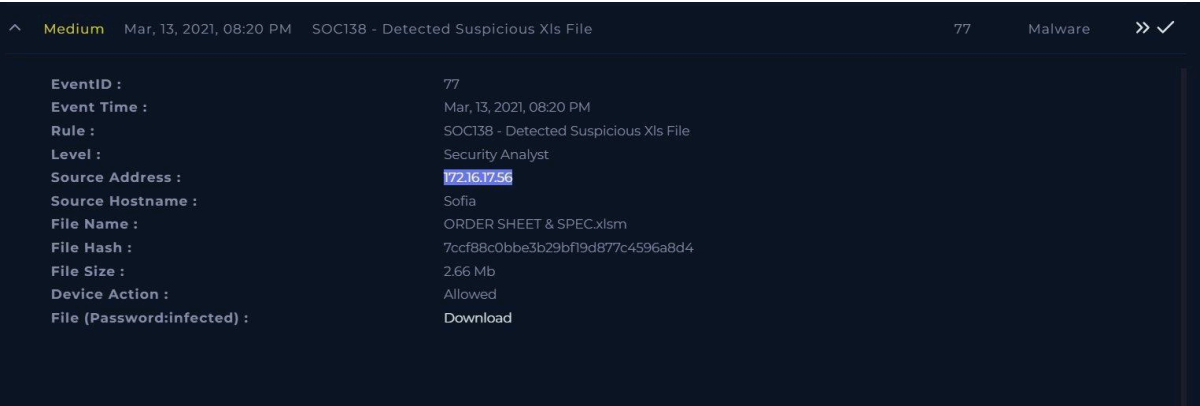
Key Finding: A four-year-old, publicly documented vulnerability (CVE-2017-11882) was the sole entry point. This is a patch management failure, not a zero-day. The attack was entirely preventable with existing controls.



Figure 1 – LetsDefend SIEM – SOC138 Alert Event ID 77 – Initial Detection Trigger

2. Alert Overview & Initial Context

The SIEM alert was rated Medium severity, but post-investigation analysis elevates this to High. The triggering artefact, ORDER SHEET & SPEC.xlsm, was embedded inside a password-protected ZIP (password: "infected") — a deliberate evasion technique. Email gateways cannot inspect the contents of an encrypted archive, allowing the malicious payload to reach the endpoint undetected. The device action was recorded as "Allowed," meaning the file passed through all perimeter controls and landed on disk.



The screenshot shows a dark-themed alert detail window. At the top, a header bar contains the severity 'Medium', the timestamp 'Mar, 13, 2021, 08:20 PM', the rule name 'SOC138 - Detected Suspicious Xls File', the event ID '77', the category 'Malware', and navigation icons. Below the header, a table lists the following details:

EventID :	77
Event Time :	Mar, 13, 2021, 08:20 PM
Rule :	SOC138 - Detected Suspicious Xls File
Level :	Security Analyst
Source Address :	172.16.17.56
Source Hostname :	Sofia
File Name :	ORDER SHEET & SPEC.xlsm
File Hash :	7ccf88c0bbe3b29bf19d877c4596a8d4
File Size :	2.66 Mb
Device Action :	Allowed
File (Password:infected) :	Download

Figure 2 – LetsDefend Alert Detail – Device Action "Allowed" – File Not Blocked

The file hash had no prior detections in the LetsDefend Threat Intelligence platform at execution time, indicating either a newly deployed sample or insufficient feed coverage. The filename "ORDER SHEET & SPEC.xlsm" is consistent with a spearphishing lure targeting procurement or finance personnel — a user profile most likely to open an unsolicited order specification document without scrutiny.

3. Incident Timeline Reconstruction

The following timeline reconstructs the full attack sequence based on firewall telemetry, endpoint process history, sandbox emulation, and DNS log analysis. All timestamps are UTC.

Time (UTC)	Phase	Event
~08:15 PM	Phishing Delivery	Attacker emails a password-protected ZIP containing ORDER SHEET & SPEC.xlsm to Sofia2020. The password "infected" is shared in the email body. The email gateway cannot inspect the encrypted archive. Delivery succeeds.
~08:18 PM	User Execution	Sofia2020 extracts and opens the XLSM file in Microsoft Excel. Excel immediately processes embedded OLE objects on file open.
~08:18 PM	CVE-2017-11882 Exploitation	An embedded Microsoft Equation 3.0 OLE object triggers eqnedt32.exe. A heap overflow (CVE-2017-11882) achieves code execution silently — no macro prompt, no user interaction required beyond opening the file.
~08:18 PM	VBA Macro Chain Fires	Auto-open VBA macros execute from Module2.bas. The chain creates WinHttp, ADODB.Stream, and WScript.Shell objects, writes asc.txt and script1.vbs to disk, and calls ShellExecuteA/Ex via dynamic API resolution to spawn cscript.exe outside the Office process tree.
~08:19 PM	PowerShell Dropper Executes	A Base64-encoded PowerShell command (-EncodedCommand) is launched. The decoded script forces TLS 1.2 and iterates through seven compromised WordPress sites to download the second-stage payload.
~08:19 PM	Payload Download & Drop	Podaliri4.exe is downloaded from https://multiwaretecnologia.com.br/js/Podaliri4.exe . A size gate (>= 26,346 bytes) blocks sandbox environments returning stub files. The file is written to %ALLUSERSPROFILE%\Podaliri4.exe.
~08:19 PM	Payload Execution	Podaliri4.exe is launched via Win32_Process.Create() (WMI), breaking the parent-child process chain from PowerShell to evade process tree analysis.
08:20 PM	C2 Beaconing Confirmed	Two firewall events: 172.16.17.56 → 177.53.143.89:443. Binary TLS payloads confirm an active, encrypted C2 session. The malware is under attacker control.
08:20 PM	SIEM Alert Fires	Rule SOC138 generates Event ID 77. The full attack chain has already completed. The alert is reactive, not preventive.
08:20 PM	DNS C2 Resolution	DNS query for multiwaretecnologia.com.br observed from 172.16.17.24, resolved to 177.53.143.89:53, confirming C2 infrastructure is reachable from inside the network.
Post-event	No Containment	Endpoint containment was never enabled. Malware remained active. No quarantine action was taken. Dwell time is unknown.

Critical Finding: The SIEM alert fired at 08:20 PM after the attack was already complete. The detection model provides zero opportunity for pre-execution intervention.

4. Affected Endpoint Profile

The source IP 172.16.17.56 belongs to the Windows 10 client machine "Sofia" (user: Sofia2020, domain: LetsDefend). As a domain-joined client, Sofia holds user credentials, cached authentication tokens, and access to shared network resources — making it a high-value lateral movement staging point. The last recorded login was October 25, 2020, suggesting an infrequently used account, which may have delayed incident detection.

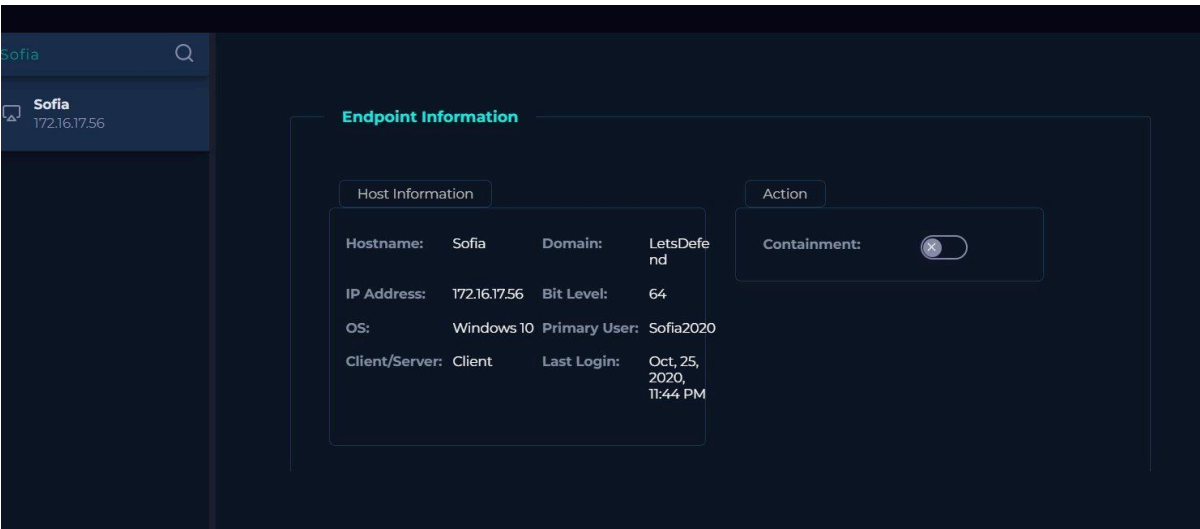


Figure 3 – LetsDefend Endpoint – Sofia Profile, Hostname Sofia, Windows 10, User Sofia2020 – Containment Disabled

The endpoint containment toggle was disabled at investigation time, leaving Sofia connected to the internal network throughout the incident. This is a critical response gap: the host acted as a live pivot point for any lateral movement initiated over the C2 channel.

The source IP was also checked in VirusTotal and the LetsDefend Threat Intelligence platform. As an internal RFC 1918 address, it returned no vendor detections — expected behaviour for a private IP. Threat Intel returned no prior entries, indicating no historical activity flagged for this endpoint before this incident.

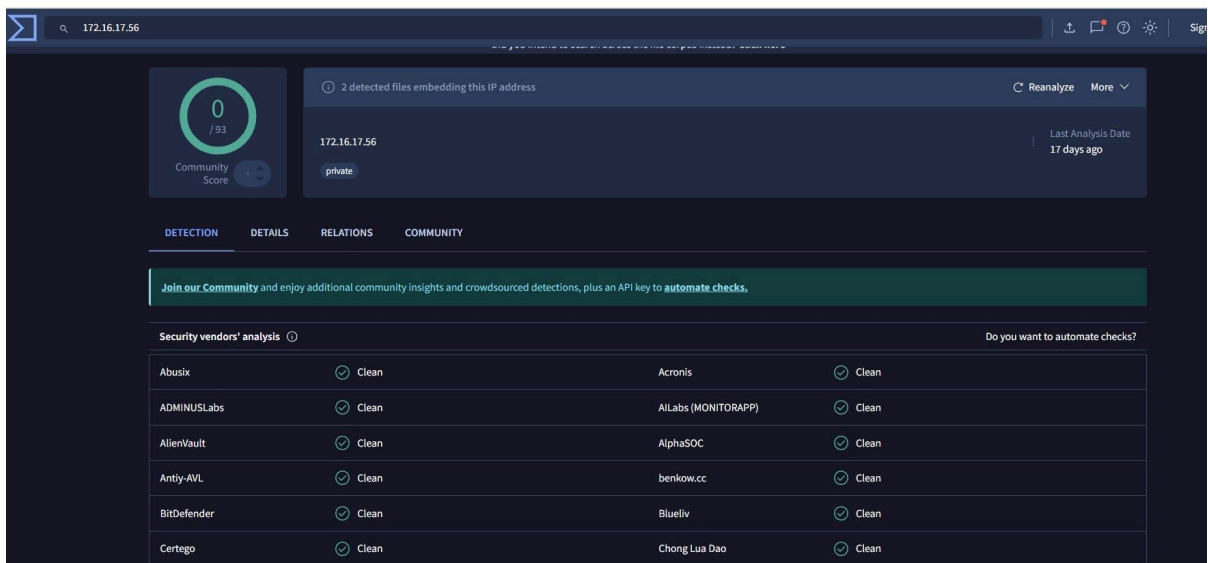


Figure 4 – VirusTotal – Internal IP 172.16.17.56 – 0/93 Clean, Expected for Private RFC 1918 Address

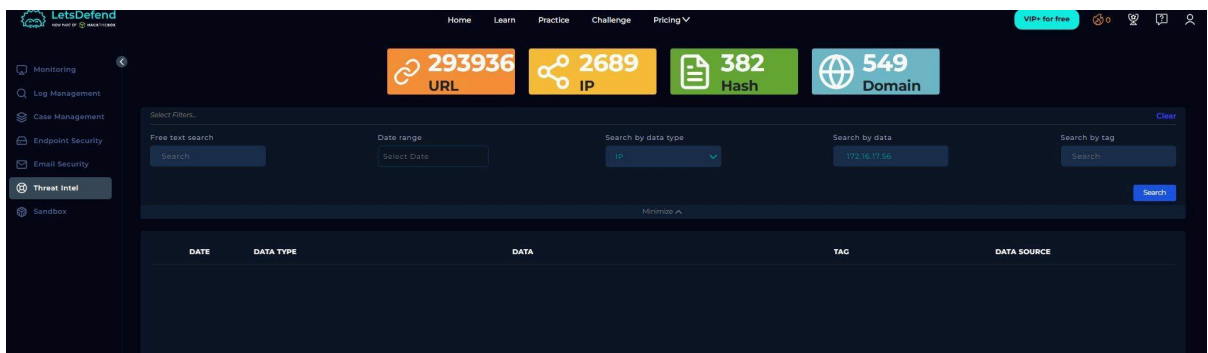
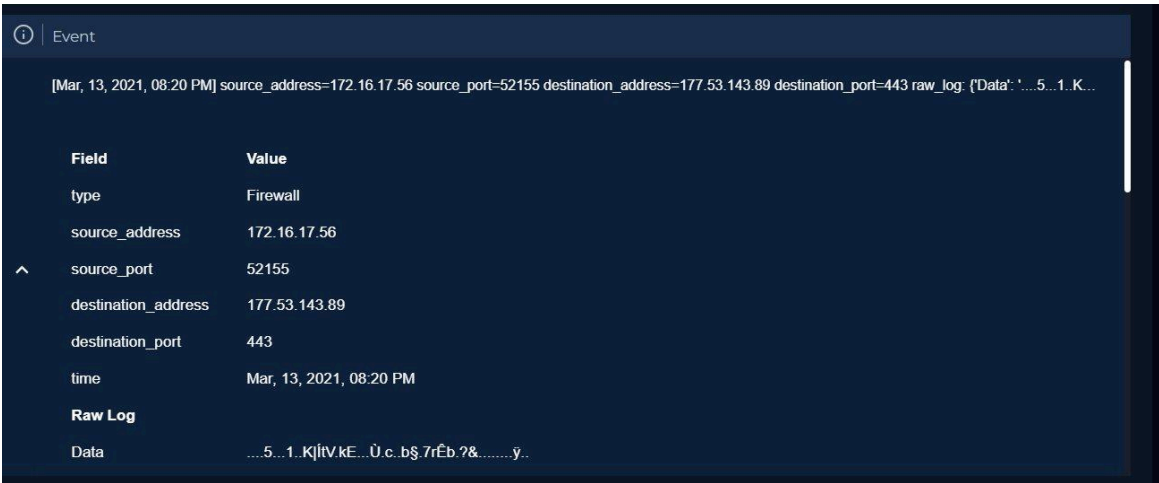


Figure 5 – LetsDefend Threat Intel – No Results for 172.16.17.56 – No Prior Threat History for This Endpoint

5. Network Activity Analysis

The firewall log for host Sofia shows two distinct outbound connections to 177.53.143.89 over port 443 at exactly 08:20 PM. Each carries a different binary-encoded payload consistent with TLS-wrapped C2 traffic. Port 443 (HTTPS) is deliberate: it traverses most corporate firewalls without inspection and blends into normal web browsing. The use of port 443 means this traffic generated no firewall alert and would not be visible to standard network monitoring.



The screenshot shows a Windows Firewall log entry for an outbound connection. The log entry is as follows:

Field	Value
type	Firewall
source_address	172.16.17.56
source_port	52155
destination_address	177.53.143.89
destination_port	443
time	Mar, 13, 2021, 08:20 PM
Raw Log	
Data	5...1.KlV.kE...Ü.c.b\$ 7rÊb.?&.....y..

Figure 6 – Firewall Logs – First Outbound Beacon to 177.53.143.89:443 – C2 Beaconsing Evidence

The two successive payloads over the same session are consistent with an initial agent check-in followed by a tasking exchange — standard behaviour for agent-style RAT frameworks such as Cobalt Strike or custom malware implants. The destination IP 177.53.143.89 is also the DNS resolver that resolved multiwaretecnologia.com.br, confirming dual-use infrastructure: the same operator controls both the payload delivery domain and the C2 listener, geolocated to Sao Paulo, Brazil.



The screenshot shows a Windows Firewall log entry for a second outbound connection. The log entry is as follows:

Field	Value
type	Firewall
source_address	172.16.17.56
source_port	52155
destination_address	177.53.143.89
destination_port	443
time	Mar, 13, 2021, 08:20 PM
Raw Log	
Data	}...y.KlV.kE...Ü.c.b\$ 7rÊb.?&.....y..

Figure 7 – Firewall Logs – Second Beacon Same TCP Session (Port 52155) – Interactive C2 Session Confirmed

Analyst Note: Both firewall events share source port 52155, confirming they belong to the same TCP session. The malware re-used the connection for a second exchange, indicating an interactive session rather than a one-shot beacon.

6. Endpoint Command Execution Analysis

Inspecting Sofia's endpoint process history revealed a PowerShell command executing with the -EncodedCommand (-ENCOD) flag. This Base64-encoded payload is designed to bypass all string-based detection rules applied to plain-text PowerShell command lines. The technique is widely abused because it trivially defeats keyword blocklists in SIEMs and EDR engines that lack script block decoding capabilities.

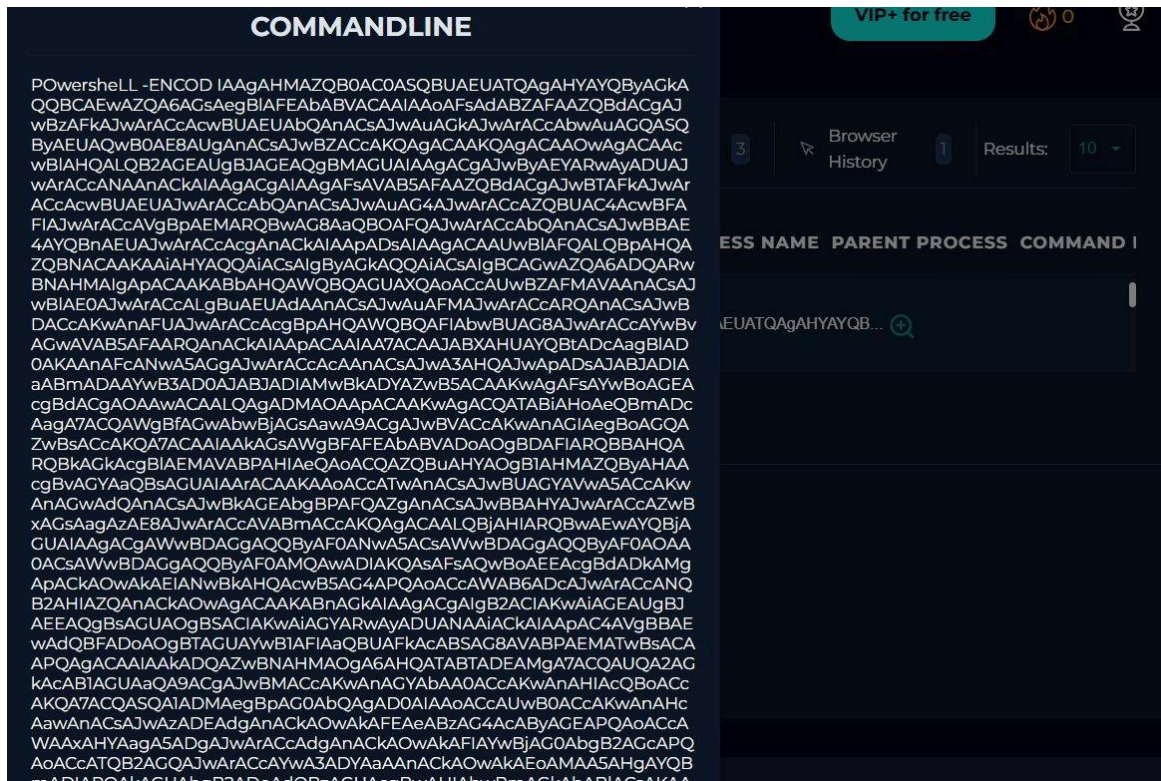


Figure 8 – Endpoint Process History – PowerShell -EncodedCommand – Obfuscated Execution Found in Command-Line History

Behavioural Breakdown of the Decoded Payload:

1. Stage 1 — Anti-Analysis Obfuscation: All .NET class names are assembled via string concatenation at runtime (e.g., "System.Net." + "WebClient"). No recognisable strings appear in the raw Base64 blob, defeating static YARA rules and keyword-based alerting.
2. Stage 2 — TLS Enforcement: The script explicitly sets SecurityProtocol = TLS12 before any network call. This ensures the HTTPS download succeeds on hardened systems and fully encrypts the transfer against network-layer inspection.
3. Stage 3 — Multi-Host Fallback: Seven compromised WordPress sites are hardcoded as sequential download sources (tudorinvest.com, dp-womenbasket.com, stylefix.co, ardos.com.br, drtheurelplasticsurgery.com, bodyinnovation.co.za, nomadco.es). This redundancy is characteristic of commercial exploit kit infrastructure.
4. Stage 4 — Sandbox Size-Gate: The downloaded binary is only executed if its file size is $\geq 26,346$ bytes. Sandboxes returning empty stub responses fail this check, producing false-negative analysis results.
5. Stage 5 — WMI Process Launch: Execution is triggered via Win32_Process.Create(), spawning the process without a parent-child relationship to PowerShell, breaking process tree visualisation in EDR tools.

Indicator of Professional TTPs: Runtime obfuscation + TLS enforcement + multi-host fallback + sandbox size-gating + WMI launch = five layered evasion techniques in a single dropper. This is not opportunistic malware. Each technique targets a specific defensive control.

7. Malware Behavioural Analysis

This section focuses on what the malware demonstrably does based on sandbox emulation, VBA decompilation, and network telemetry — not on AV detection counts. Evidence is grouped by investigative phase: exploitation, macro execution, payload delivery, and multi-platform corroboration.

7.1 Exploitation Vector — CVE-2017-11882

The XLSM file embeds a Microsoft Equation 3.0 OLE object — the exploit primitive for CVE-2017-11882. This heap overflow in eqnedt32.exe, patched via MS17-006 in November 2017, allows arbitrary code execution when a malformed Equation object is parsed by an unpatched Office installation. Exploitation requires nothing beyond the victim opening the document; there are no security dialogs, no macro prompts, and no interaction beyond the initial open action. Even with macros fully disabled via Group Policy, this exploit would still execute.

Sandbox emulation confirmed that ShellExecuteA@SHELL32.dll and ShellExecuteEx@SHELL32.dll were both resolved at runtime via dynamic API resolution. Neither call appears in the static import table. The exploit code reconstructs its execution environment post-overflow using a standard heap shellcode technique designed to evade import-based static analysis.

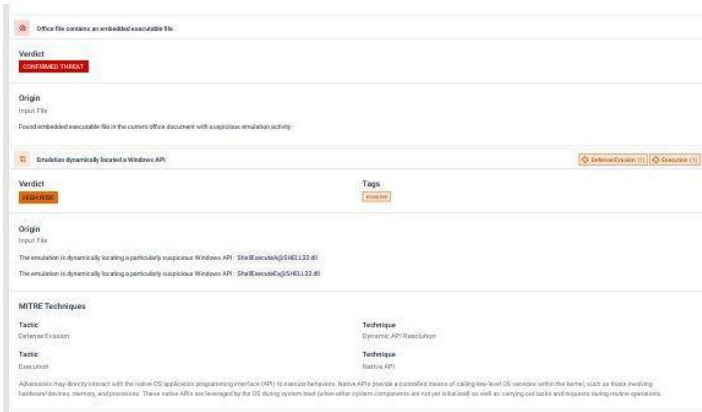


Figure 9 – FileScan.io Indicators – Office File Contains Embedded Executable – ShellExecuteA/Ex Dynamically Resolved at Runtime (High Risk)

7.2 Macro Execution Chain

Post-exploit, auto-open VBA macros fire from Module2.bas and the Sheet modules. The macros use CreateObject to instantiate WinHttp.WinHttpRequest.5.1, ADODB.Stream, Scripting.FileSystemObject, and WScript.Shell, building a complete file download-and-execute engine inside the Office document. The chain spawns cscript.exe, writes intermediate VBScript files (asc.txt → script1.vbs) to disk, and invokes them via ShellExecute to detach execution from the Office process, breaking process tree-based EDR detection.

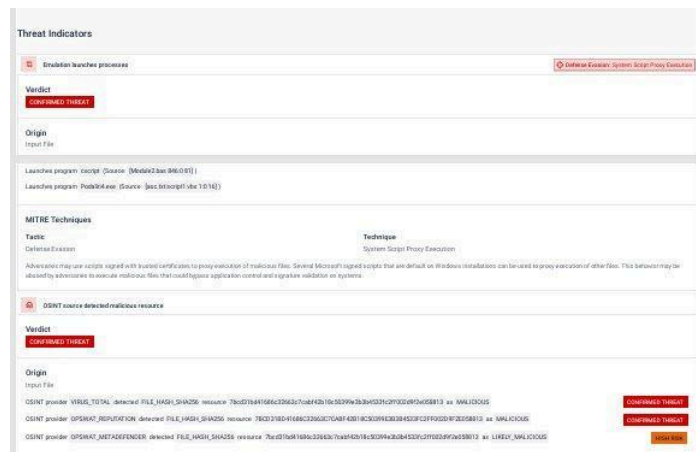


Figure 10 – FileScan.io Emulation – cscript.exe Launched from Module2.bas, Podaliri4.exe from script1.vbs – T1216 System Script Proxy Execution Confirmed

7.3 Payload Delivery and Drop

FileScan.io produced the most comprehensive behavioural analysis. The file received a Confirmed Threat verdict with 3 malicious indicators and 8 high-risk indicators. The sandbox tracked the full execution chain from Equation Editor exploitation through to the HTTP GET request and process drop. The overview page confirms the file is tagged as xlsx / exploit / dropper / evasive / macros.

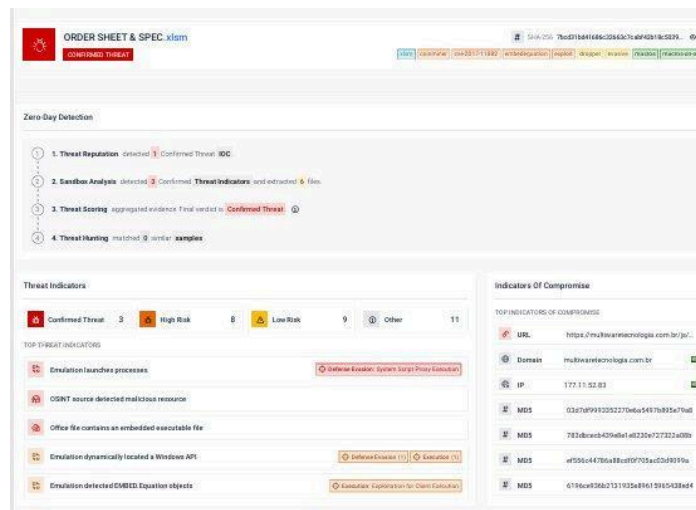


Figure 11 – FileScan.io Overview – ORDER SHEET & SPEC.xlsx – Confirmed Threat, 3 Malicious Indicators, Tags: xlsx/exploit/dropper/evasive/macros

The sandbox confirms Podaliri4.exe was downloaded from <https://multiwaretecnologia.com.br/js/Podaliri4.exe> and written to %ALLUSERSPROFILE%\Podaliri4.exe — a globally writable directory that does not require administrative privileges, minimising the risk of UAC prompts. OSINT provider OPSWAT confirmed the C2 URL as malicious.

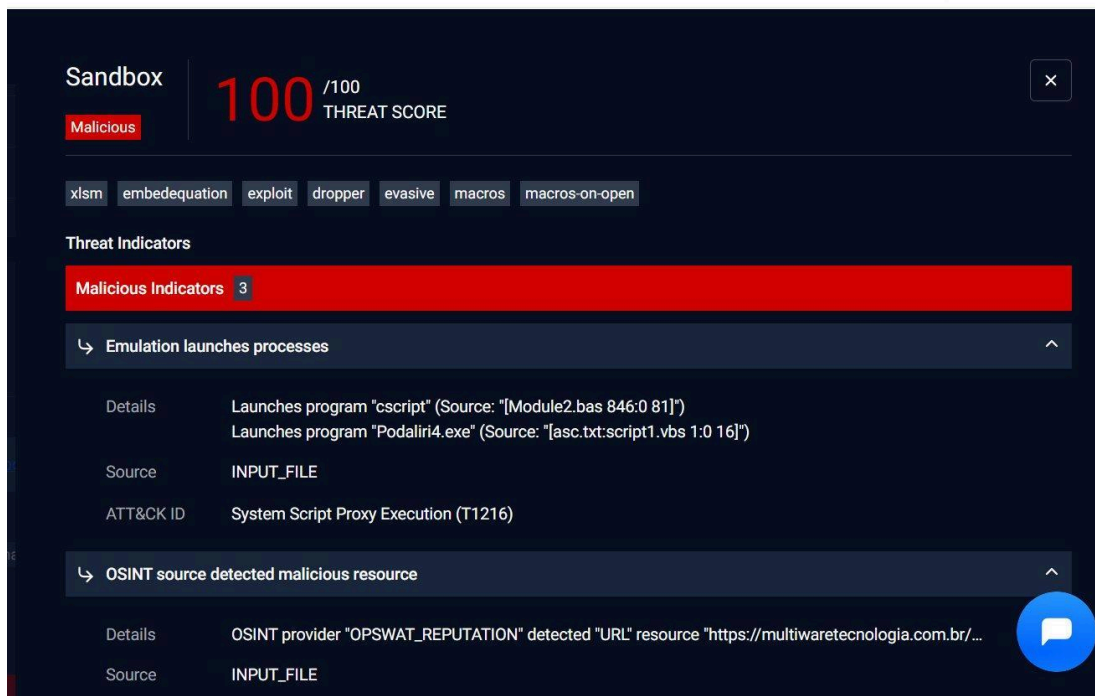


Figure 12 – FileScan.io Sandbox – 100/100 Threat Score – 3 Malicious Indicators with Full Emulation Detail



Figure 13 – FileScan.io IOC Page – C2 URL multiwaretecnologia.com.br/js/Podaliri4.exe – Domain and IPs 177.53.143.89 / 177.11.52.83 Confirmed Malicious

Key FileScan.io Confirmed Behaviours:

- cscript.exe launched from Module2.bas (T1216 — System Script Proxy Execution)
- Podaliri4.exe launched from asc.txt:script1.vbs
- ShellExecuteA@SHELL32.dll and ShellExecuteEx@SHELL32.dll dynamically resolved at runtime (T1129)
- Microsoft Equation 3.0 OLE objects detected — CVE-2017-11882 / CVE-2018-0802 exploitation vector (T1203)
- HTTP GET confirmed to <https://multiwaretecnologia.com.br/js/Podaliri4.exe>
- Podaliri4.exe written to %ALLUSERSPROFILE%\Podaliri4.exe
- OSINT (OPSWAT) confirmed the C2 URL as malicious at analysis time

7.4 Multi-Platform Corroboration

Five additional platforms corroborate the FileScan.io findings. Each is shown in order of investigative relevance: primary dynamic analysis, then static hash analysis, then file sanitization capability, then additional AV corroboration.

The screenshot displays the Hybrid Analysis web interface. At the top, the 'HYBRID ANALYSIS' logo is visible. Below the header, the 'Analysis Overview' section provides details for a submission named '7ccf88c0bbe3b29bf19d877c4596a8d4.zip'. The submission is 68KiB in size, of type 'data' (compressed zip), and has a MIME type of 'application/zip'. Its SHA256 hash is 'a53db45f1d4a2f36ebc0b0e268d2073baba89ca6c1d05fe9a06ef395e8658a51'. It was submitted on 2021-03-20 and has been scanned by anti-virus software on 2025-06-20 and in a sandbox on 2025-03-22. A red 'malicious' badge is prominently displayed, along with a 'Threat Score: 100/100' and 'AV Detection: 14%'. The file is labeled as 'CVE-2017-11882'. Social sharing options for Post, Link, and E-Mail are available. A 'Community Score' of 0 is shown at the bottom. The 'Anti-Virus Results' section below indicates that results are missing and were last updated 8 months ago, with a 'Click to Refresh' button. A 'MetaDefender Multi Scan Analysis' section is partially visible at the bottom.

Figure 14 – Hybrid Analysis – Malicious Verdict, 100/100 Threat Score – Labeled CVE-2017-11882, Submitted ZIP Hash Confirmed

The screenshot shows the VirusTotal analysis page for a file with SHA256 hash '7bcd31bd41686c32663c7cabf42b18c50399e3b3b4533fc2ff002d9f2e058813'. The file is identified as 'ORDER SHEET & SPEC.xlsm' and is 2.66 MB in size. A 'Community Score' of 48/67 is shown, with a red indicator for malicious intent. A banner states '48/67 security vendors flagged this file as malicious'. The file is tagged with 'cve-2017-11882' and other tags like 'exploit', 'macros', and 'auto-open'. The 'DETECTION' tab is active, showing a 'Code insights' section that notes obfuscation in the macro. A 'Crowdsourced AI' section at the bottom shows a 'Hispacec' flag for the file as malicious, citing signs of malicious intent in the macros.

Figure 15 – VirusTotal – ZIP Container (SHA256: 7bcd31...) – Broad Malicious Consensus, Tags: exploit/macros/auto-open/cve-2017-11882

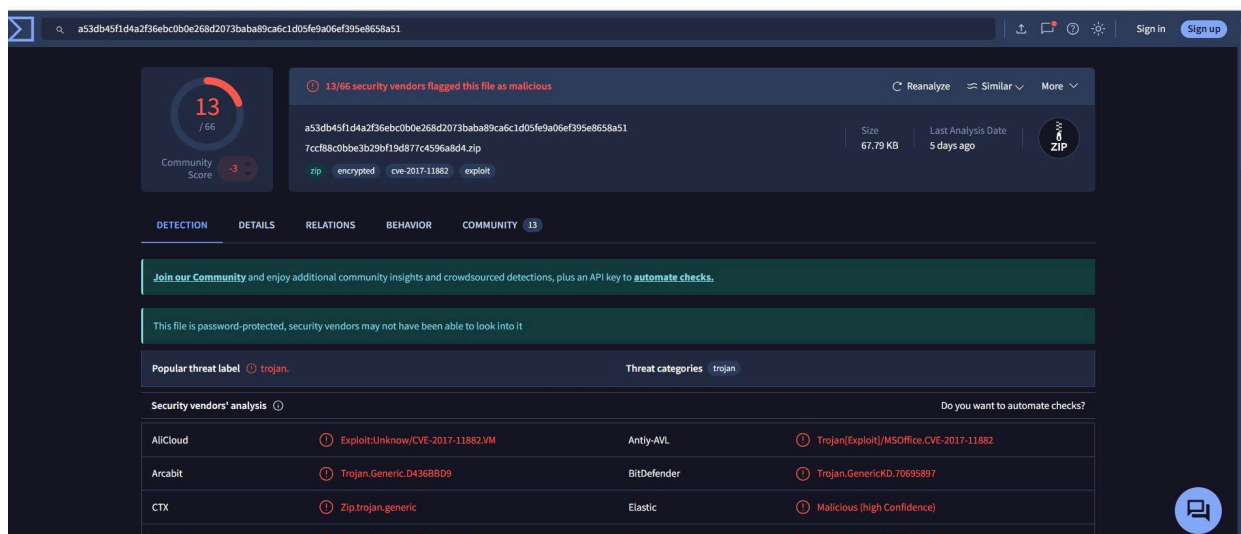


Figure 16 – VirusTotal – hash (SHA256: a53db45f1d4a2f36ebc0b0e268d2073baba89ca6c1d05fe9a06ef395e8658a51) – Malicious Verdict, Password-Protection Limited Inspection by Some Engines

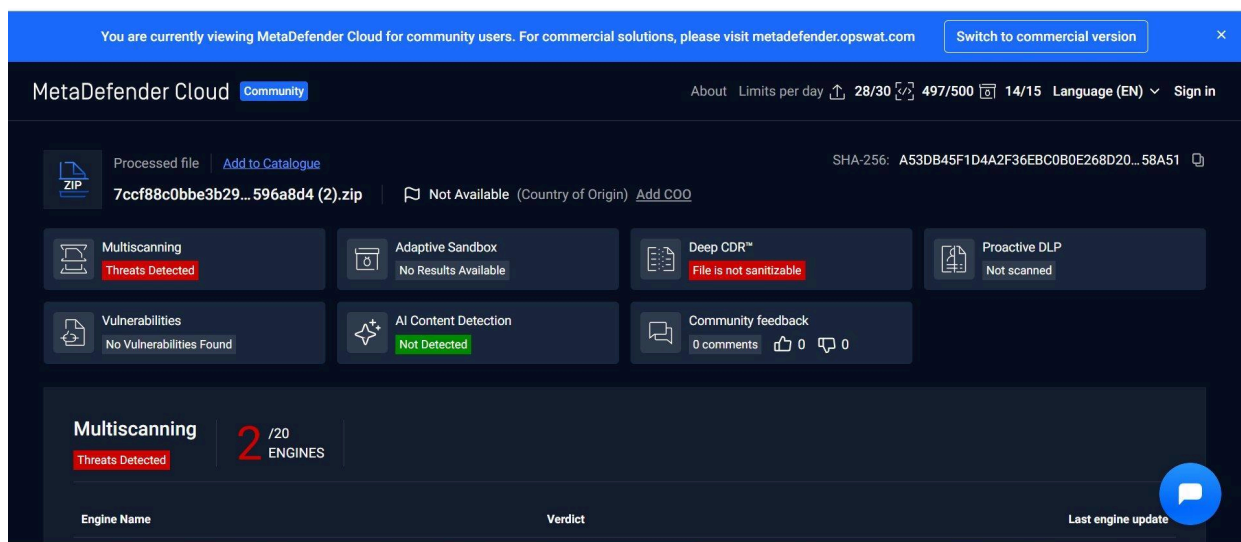


Figure 17 – MetaDefender Cloud – Threats Detected (Multiscanning) – Deep CDR Cannot Sanitize File, AI Content Detection Evaded

Login

There are 2 engine detections

SHA256: a53db45f1d4a2f36ebc0b0e268d2073baba89ca6c1d05fe9a06ef395e8658a51

SHA1: 5a99f6b3b106daf23ba2c29f2ff94cb118703414

MD5: adee407a5d9f4425707fe5bd4c25aa14

File size: 67.79 KB (69412)

File Type: zip

First submission: 2021/03/15 21:09:22 (GMT+1)

Last analysis: 2024/09/03 06:41:31 (GMT+1)

Engine detection
Static information

Last detection time 2024-09-03 06:41:31

Rescan

Engine	Result	Engine	Result
NANO	Trojan.Script.ExpKit.fbenub	Emsisoft	Trojan.GenericKD.70695897 (B)
AVG	Undetected	Defenx	Undetected

Figure 18 – VirSCAN – Trojan.Script.ExpKit.fbenub (NANO) + Trojan.GenericKD.70695897 (Emsisoft) – Exploit Kit Script Delivery Family Confirmed

Jotti's malware scan
Scan file
Search hash
Language
FAQ
Privacy
API
Contact

Report for scan job: mcwj3k7gw3

Name: 7ccf88c0bbe3b29bf19d877c4596a8d4 (2).zip

Size: 67.79kB (69,412 bytes)

Type: Zip archive

First seen: March 3, 2026 at 2:40:28 PM GMT+1

MD5: adee407a5d9f4425707fe5bd4c25aa14

SHA1: 5a99f6b3b106daf23ba2c29f2ff94cb118703414

Status: Scan finished. 3/13 scanners reported malware.

Scan taken on: March 3, 2026 at 2:40:29 PM GMT+1

	Mar 3, 2026	Found nothing		Mar 3, 2026	Trojan.GenericKD.70695897		Mar 3, 2026	Found nothing
	Mar 3, 2026	Found nothing		Mar 3, 2026	Found nothing		Mar 3, 2026	Trojan.GenericKD.70695897
	Mar 3, 2026	Found nothing		Mar 3, 2026	Trojan.GenericKD.70695897		Mar 3, 2026	Found nothing
	Mar 3, 2026	Found nothing		Mar 3, 2026	Found nothing		Mar 2, 2026	Found nothing
	Mar 3, 2026	Found nothing						

© 2004-2026 Jotti

Figure 19 – Jotti Malware Scan – Bitdefender, G DATA, eScan All Classify as Trojan.GenericKD.70695897 – Multi-Vendor Confirmation

8. Playbook Execution

8.1 Malware Classification

The playbook instructs the analyst to classify the malware using third-party platforms before proceeding to containment decisions.

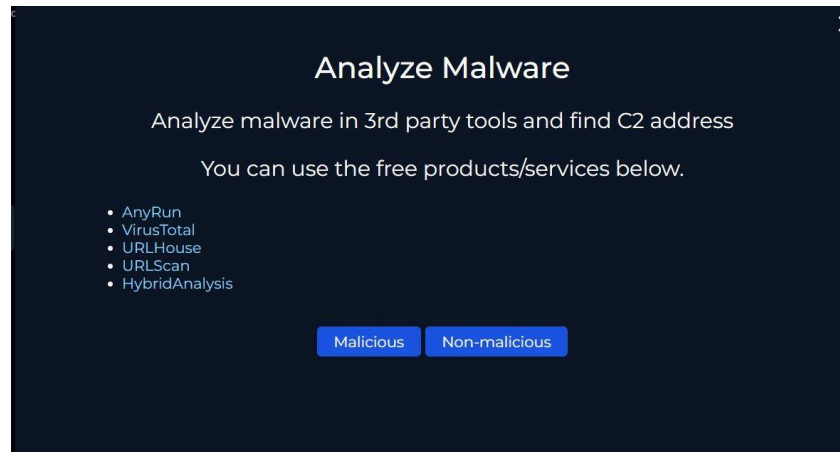


Figure 20 – LetsDefend Playbook – Analyze Malware Step – Available Tools: AnyRun, VirusTotal, URLHouse, URLScan, HybridAnalysis

All platforms returned a malicious verdict. Behavioural evidence — CVE exploitation, obfuscated script execution, payload download, and active C2 beaconing — is conclusive independent of any AV detection count.

Playbook Decision: MALICIOUS

8.2 C2 Access Verification

The playbook requires checking whether the C2 domain was successfully resolved from inside the network. Log Management was searched for multiwaretecnologia.com.br.

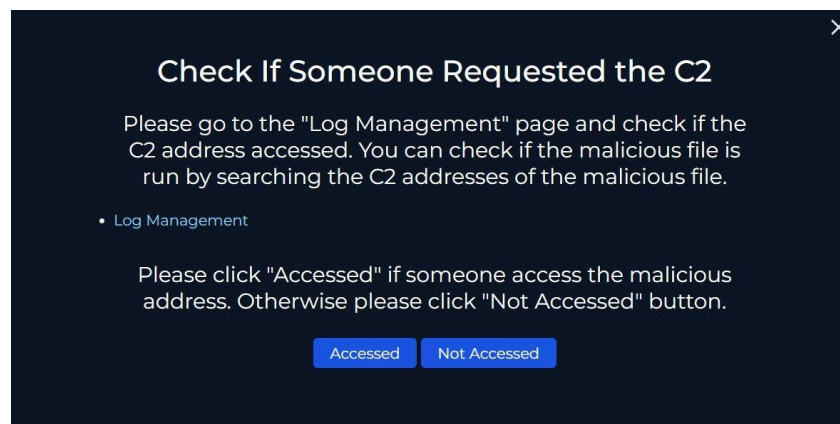


Figure 21 – LetsDefend Playbook – Check If Someone Requested the C2 Address – Analyst Directed to Log Management

One DNS event was confirmed: an internal host sent a query to 177.53.143.89:53 that successfully resolved multiwaretecnologia.com.br. This is direct proof that the malware executed and reached its command infrastructure from inside the network perimeter.

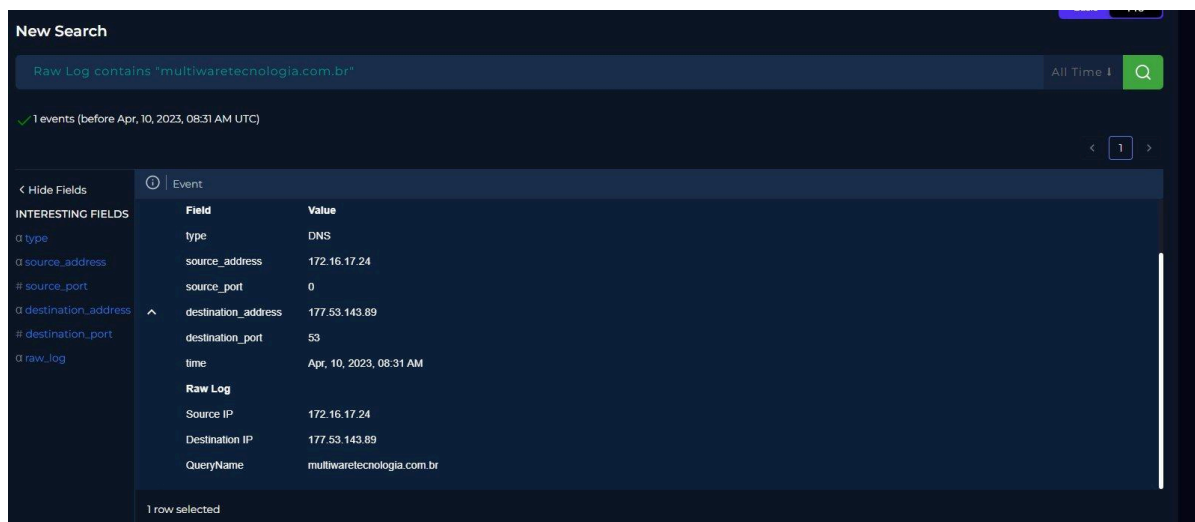


Figure 22 – DNS Logs – Query for multiwaretecnologia.com.br Resolved via 177.53.143.89:53 – C2 Resolution Confirmed

Playbook Decision: ACCESSED

8.3 Quarantine Status

The playbook checks whether the affected endpoint has been quarantined or cleaned by the Endpoint Security solution.



Figure 23 – LetsDefend Playbook – Quarantine Check – Malware Not Quarantined, Endpoint Containment Was Disabled

Endpoint Security confirmed containment was disabled on Sofia. No quarantine action had occurred. The threat was live at investigation time.

Playbook Decision: NOT QUARANTINED — ACTIVE THREAT

9. Impact Analysis

Given confirmed code execution, an active C2 session, and an uncontained endpoint, the following impact scenarios are treated as live risks until forensic evidence disproves them. Worst-case assumptions apply until the full scope of compromise is established.

9.1 Credential Compromise

Podaliri4.exe had direct access to the Sofia endpoint at user level. Standard post-exploitation routines performed by RATs and stealers include extraction of browser-stored credentials, Windows Credential Manager entries, and potentially LSASS memory contents if privilege escalation was attempted. Sofia2020's credentials must be treated as fully compromised. Any service or application authenticated by Sofia2020 since last login (October 25, 2020) should be considered exposed.

9.2 Lateral Movement Risk

Sofia is a domain-joined Windows 10 client with access to internal network shares and Active Directory resources. With valid user credentials and an active C2 channel, an attacker can enumerate the domain, identify high-value targets, and initiate lateral movement. If Sofia2020 holds any cached privileged tokens or reused passwords, escalation to broader network access is feasible. The host remained connected throughout the dwell period with no isolation.

9.3 Data Exfiltration Risk

The established TLS channel to 177.53.143.89:443 provides a fully encrypted conduit for data exfiltration that bypasses standard firewall inspection on port 443. Any file accessible to Sofia2020 — documents, spreadsheets, emails, VPN configurations, credentials — could have been exfiltrated without generating a network alert. No deep packet inspection was applied to outbound HTTPS traffic.

9.4 Business and Regulatory Impact

Potential business impacts include: exposure of customer or partner data triggering regulatory obligations (GDPR, HIPAA, or equivalent), compromise of internal credentials enabling further network intrusion, disruption of business processes if persistence mechanisms were installed, and reputational damage if the compromise is disclosed externally. Dwell time is unknown; the longer the interval, the broader the blast radius.

9.5 Scope of Exposure

Current Status: One confirmed compromised endpoint (Sofia, 172.16.17.56). One active C2 session. One credential at risk (Sofia2020). Lateral movement window open since 08:20 PM Mar 13, 2021. Full scope unknown pending endpoint forensics and Active Directory audit log review.

10. MITRE ATT&CK — Attack Chain Narrative

Rather than treating MITRE techniques as isolated checkboxes, this section narrates how each kill chain phase enabled the next, and what that means for the defensive posture of the affected organisation.

Phase 1: Initial Access → Execution

The attack began with a phishing email delivering a password-encrypted ZIP (T1566.001 — Spearphishing Attachment). The encryption served a dual purpose: bypassing email AV scanning, and creating a social engineering pressure point requiring the user to enter the password — reinforcing the perceived legitimacy of the document.

Critically, execution did not depend on macro enablement. CVE-2017-11882 (T1203 — Exploitation for Client Execution) triggered silently through the Equation Editor on document open. Even with macros fully disabled via Group Policy, the exploit would still execute. The VBA macros were a secondary, redundant execution mechanism. This distinction is operationally significant: hardening macro policy alone would not have prevented this attack.

Phase 2: Execution → Defense Evasion

The macro chain (T1059.005 — Visual Basic) was designed to defeat both static and dynamic analysis simultaneously. Dynamic API resolution (T1129) for ShellExecute meant the API calls would not appear in a static import scan. Spawning cscript.exe as intermediary (T1216) broke the Office process chain. The PowerShell stage (T1059.001) used Base64 encoding (T1027) and runtime string construction to evade keyword-based detection. WMI process launch (T1047) broke parent-child process telemetry in EDR tools.

Five distinct evasion techniques were layered in sequence. No single defensive control would have blocked the entire chain. This reflects a deliberate design philosophy: assume some defences will be present, and ensure execution succeeds through redundancy. This is the architecture of professional, operationally-tested malware.

Phase 3: C2 → Persistent Control

Podaliri4.exe was downloaded (T1105 — Ingress Tool Transfer) from a compromised WordPress site, providing legitimate domain reputation and complicating URL-based blocking. C2 communication runs over HTTPS/TLS (T1573.001) on port 443, encrypting all traffic and defeating network-layer inspection. The delivery pattern — compromised legitimate hosting for payload distribution, dedicated C2 server, hardcoded fallback sites — is consistent with commercial exploit kit operations. The threat actor does not need zero-days; they rely on predictably unpatched environments.

Technique Reference Table

Phase	Tactic	Technique	ID
1	Initial Access	Spearphishing Attachment (password ZIP)	T1566.001
1	Execution	Exploitation for Client Execution — CVE-2017-11882	T1203
2	Execution	Visual Basic — auto-open VBA macro chain	T1059.005

2	Execution	PowerShell — Base64 -EncodedCommand downloader	T1059.001
2	Execution	Native API — ShellExecuteA/Ex via SHELL32.dll	T1106
2	Execution	User Execution — macro triggers on file open	T1204.002
2	Defense Evasion	System Script Proxy Execution — cscript.exe	T1216
2	Defense Evasion	Dynamic API Resolution — runtime import	T1129
2	Defense Evasion	Obfuscated Files or Information — Base64 PS	T1027
2	Defense Evasion	WMI Execution — Win32_Process.Create()	T1047
2	Defense Evasion	Modify Registry (alert-mapped)	T1112
3	C2	Ingress Tool Transfer — Podaliri4.exe download	T1105
3	C2	Encrypted Channel — HTTPS/TLS port 443	T1573.001

11. Detection Gaps & Control Weaknesses

A senior-level investigation must answer not just what happened, but why the controls failed. Each gap below maps to a specific missed opportunity in the kill chain. Together they explain how a well-known, thoroughly-documented attack chain reached full execution in a managed corporate environment.

Control Gap	Observed Evidence	Security Implication
Email Gateway: Encrypted archive not inspected	Malicious XLSM delivered inside password-protected ZIP; gateway cannot inspect encrypted content	Any threat actor can bypass email AV by encrypting attachments. Remediation requires a sandbox that detonates archives using passwords extracted from the email body, or a policy quarantining encrypted attachments from external senders.
Patch Management: CVE-2017-11882 unpatched	Equation Editor (eqnedt32.exe) active and unpatched 4+ years after MS17-006 patch release (Nov 2017)	Exploitation required no user action beyond file open. A quarterly or monthly patch cadence would have eliminated this vector entirely. This is a process failure, not a capability gap.
Macro Policy: No Group Policy enforcement	Auto-open VBA macros executed without restriction; Protected View not enforced for externally-sourced files	GPO: "Block all macros without notification" for internet-sourced Office documents would have interrupted the secondary macro chain (though not the CVE exploit itself).
PowerShell: No Script Block Logging or AMSI	PowerShell -EncodedCommand executed without decoding, logging, or blocking; no Constrained Language Mode	Script Block Logging decodes Base64 before execution and writes cleartext to the event log. AMSI feeds decoded content to the EDR engine. Either control would have exposed the payload.
EDR: No behavioural detection triggered	Office → cscript, PowerShell -EncodedCommand, WMI process creation, and outbound TLS to unknown IP produced no alert or isolation	A behavioural rule (Office spawning script hosts, PowerShell with encoded command, WMI to external IP) should have auto-isolated the host before payload execution completed.
Containment: Disabled on affected endpoint	Sofia had no automated containment policy; analyst manual action was the only response mechanism	Manual-only containment fails at scale and during out-of-hours events. Automated isolation for confirmed high-severity detections should be standard operating posture with manual override available.
Alert Severity: Medium miscalibration	SOC138 fired as Medium despite a complete kill chain being in progress; no auto-escalation occurred	CVE-2017-11882 exploitation should auto-escalate to High and trigger immediate response. Miscalibrated severity directly delays containment and increases dwell time.

Root Cause: No single control failure caused this incident. The attack chain passed through every defensive layer unimpeded because defence-in-depth was not implemented. Each gap above is independently exploitable. Fixing all seven raises the cost of attack significantly without guaranteeing immunity.

12. Indicators of Compromise

Type	Indicator / Value	Significance
MD5	7ccf88c0bbe3b29bf19d877c4596a8d4	ORDER SHEET & SPEC.xlsm — primary malicious dropper
SHA256	7bcd31bd41686c32663c7cabf42b18c50399e3b3b4533fc2ff002d9f2e058813	XLSM payload — confirmed malicious by all platforms
SHA256 (ZIP)	a53db45f1d4a2f36ebc0b0e268d2073bab a89ca6c1d05fe9a06ef395e8658a51	ZIP container — password-protected delivery vehicle
URL	https://multiwaretecnologia.com.br/js/Podaliri4.exe	C2 payload download URL — confirmed active at incident time
Domain	multiwaretecnologia.com.br	C2 domain — resolved within network, confirmed via DNS log
IP	177.53.143.89	C2 server — dual-use: payload host + C2 listener (Sao Paulo, BR)
IP	177.11.52.83	Additional C2 infrastructure IP — same operator
File	Podaliri4.exe	Second-stage payload — dropped to %ALLUSERSPROFILE%
File	asc.txt, script1.vbs	Intermediate VBScript dropper files written by macro chain
Process	cscript.exe	Spawned by Office macro as proxy execution vehicle (T1216)
Process	eqnedt32.exe	Equation Editor — CVE-2017-11882 exploitation process
API Call	ShellExecuteA/Ex @ SHELL32.dll	Dynamically resolved at runtime — executes dropped payload
CVE	CVE-2017-11882	MS Equation Editor heap overflow — CVSS 7.8, patched Nov 2017

13. Verdict & Required Actions

TRUE POSITIVE — ACTIVE COMPROMISE — IMMEDIATE RESPONSE REQUIRED

A confirmed, fully-executed intrusion. The threat actor delivered an exploit, achieved code execution, dropped a second-stage payload, and established an encrypted C2 channel. The endpoint is uncontained. Every minute of delay expands the potential blast radius.

Priority 1 — Immediate (Within 1 Hour):

- ISOLATE Sofia (172.16.17.56): enable network containment immediately; preserve disk image for forensics before any remediation action
- BLOCK at perimeter: firewall rules to drop all traffic to/from 177.53.143.89, 177.11.52.83, and multiwaretecnologia.com.br; add to DNS blacklist
- INVALIDATE Sofia2020 credentials: force password reset across all systems; revoke active tokens and sessions

Priority 2 — Short-Term (Within 24 Hours):

- FORENSIC TRIAGE: hunt for Podaliri4.exe, asc.txt, script1.vbs, registry run keys, scheduled tasks, and any persistence mechanisms installed by the payload
- THREAT HUNT: search all endpoints for the same file hashes, C2 IPs, and PowerShell -EncodedCommand usage in the same timeframe
- EMAIL INVESTIGATION: identify the phishing message, its sender, and all other recipients who may have received the same lure

Priority 3 — Remediation (Within 1 Week):

- PATCH: apply MS17-006 to all unpatched endpoints; disable or remove eqnedt32.exe organisation-wide via GPO or file system restriction
- ENFORCE macro policy: GPO to block all macros in externally-sourced Office documents; enable Protected View for email attachments
- HARDEN PowerShell: enable Script Block Logging, AMSI integration, and Constrained Language Mode; alert on any -EncodedCommand usage
- ENABLE automated containment: configure EDR to auto-isolate hosts on confirmed high-severity malware detections

14. Lessons Learned

14.1 Patch Management Failure — CVE-2017-11882

CVE-2017-11882 was disclosed in November 2017 and patched immediately. By March 2021, it had been weaponised in mass campaigns for over three years and is trivially detected by any automated vulnerability scanner. Its presence on this endpoint is not a zero-day situation — it is a systematic failure of the patch management process. Remediation requires not just applying the patch but reviewing the patch cadence policy, asset inventory completeness, and the exception management process that allowed this gap to persist for four years.

14.2 Email Security Bypass via Encrypted Archive

Delivering malware in a password-encrypted archive is one of the oldest and most effective email gateway bypass techniques. It is trivially executed and broadly understood by both attackers and defenders. The organisation had no capability to detonate or inspect password-protected archives. This should be addressed by deploying a sandbox that attempts detonation using passwords found in the email body, or by implementing a policy that quarantines encrypted archives from external senders pending manual review.

14.3 Macro Execution Policy Absent

While CVE-2017-11882 would have executed independently of macro settings, unrestricted VBA macros provided additional execution redundancy. Microsoft provides Group Policy settings to block macros in documents sourced from the internet. The absence of this control — despite macro-based malware being the dominant Office attack vector for over a decade — represents an unacceptable residual risk. Every unmanaged macro policy is an open invitation.

14.4 EDR PowerShell Restrictions Not Deployed

PowerShell -EncodedCommand is a well-documented obfuscation indicator. Script Block Logging, available since PowerShell 5.0, decodes and logs all PowerShell execution in cleartext regardless of encoding method. AMSI allows EDR solutions to inspect decoded scripts in-memory before execution. Constrained Language Mode would have prevented the WebClient download logic entirely. The simultaneous absence of all three controls allowed the entire dropper stage to complete without generating a single alert.

14.5 No Automated Containment Policy

When a host is confirmed compromised, every second it remains connected to the internal network extends the attacker's window. The containment toggle for Sofia was off, and no automated policy triggered isolation. Response speed depended entirely on analyst manual action — a model that fails under volume, during out-of-hours events, and when dwell time has already expanded the blast radius. Automated containment for confirmed high-severity detections, with analyst override available, should be the default operating posture.

Strategic Note: Each lesson above is a separately exploitable gap. Any one of the five would have been sufficient for this campaign to succeed. Closing all five does not prevent every future attack, but it forces threat actors to invest significantly more capability — making the environment unprofitable relative to easier targets.

— *End of Report* —

SOC138 — Event ID 77 — LetsDefend Blue Team Lab — Senior Analyst Report